Please support the OWASP mission to improve software security through open source initiatives and community education. Donate Now!





This website uses cookies to analyze our traffic and only share that information with our analytics partners. Accept

ABOUT

OWASP API Security Project

Join

Watch 166 Star 2,238

Main | Acknowledgments | Join | News | RoadMap | Translations

Check out the new OWASP API Security Top 10 2023 !

What is API Security?

A foundational element of innovation in today's app-driven world is the API. From banks, retail and transportation to IoT, autonomous vehicles and smart cities, APIs are a critical part of modern mobile, SaaS and web applications and can be found in customer-facing, partner-facing and internal applications. By nature, APIs expose application logic and sensitive data such as Personally Identifiable Information (PII) and because of this have increasingly become a target for attackers. Without secure APIs, rapid innovation would be impossible.

API Security focuses on strategies and solutions to understand and mitigate the unique vulnerabilities and security risks of Application Programming Interfaces (APIs).

API Security Top 10 2023

Here is a sneak peek of the 2023 version:

The OWASP® Foundation works to improve the security of software through its community-led open source software projects, hundreds of chapters worldwide, tens of thousands of members, and by hosting local and global conferences.

API Security Information

OWASP DOCUMENTATION PROJECT

Builders Breakers Defenders

CC BY SA

Downloads or Social Links

This website uses cookies to analyze our traffic and only share that information with our analytics partners. Accept

handle object identifiers, creating a wide attack surface of Object Level Access Control issues. Object level authorization checks should be considered in every function that accesses a data source using an ID from the user. Continue reading.

- **API2:2023 - Broken Authentication**

  Authentication mechanisms are often implemented incorrectly, allowing attackers to compromise authentication tokens or to exploit implementation flaws to assume other user's identities temporarily or permanently. Compromising a system's ability to identify the client/user, compromises API security overall. Continue reading.

- **API3:2023 - Broken Object Property Level Authorization**

  This category combines API3:2019 Excessive Data Exposure and API6:2019 - Mass Assignment, focusing on the root cause: the lack of or improper authorization validation at the object property level. This leads to information exposure or manipulation by unauthorized parties. Continue reading.

- **API4:2023 - Unrestricted Resource Consumption**

  Satisfying API requests requires

GraphQL Cheat Sheet
GitHub Discussions
Mailing List

Code Repository

GitHub

Leaders

Erez Yalon
Inon Shkedy
Paulo Silva

Upcoming OWASP Global Events

OWASP Global AppSec EU 2026 - Vienna, Austria

- June 22-26, 2026

OWASP Global AppSec USA 2026 - San Francisco, CA

- November 2-6, 2026

OWASP Global AppSec EU 2027 - Vienna, Austria

- June 21-25, 2027

OWASP Global AppSec USA 2027 - Atlanta, GA

- September 20-24, 2027

OWASP Global AppSec EU 2028 - Vienna, Austria

- June 19-23, 2028

This website uses cookies to analyze our traffic and only share that information with our analytics partners. Accept

available by service providers via API integrations, and paid for per request. Successful attacks can lead to Denial of Service or an increase of operational costs. Continue reading.

- **API5:2023 - Broken Function Level Authorization**

  Complex access control policies with different hierarchies, groups, and roles, and an unclear separation between administrative and regular functions, tend to lead to authorization flaws. By exploiting these issues, attackers can gain access to other users' resources and/or administrative functions. Continue reading.

- **API6:2023 - Unrestricted Access to Sensitive Business Flows**

  APIs vulnerable to this risk expose a business flow - such as buying a ticket, or posting a comment - without compensating for how the functionality could harm the business if used excessively in an automated manner. This doesn't necessarily come from implementation bugs. Continue reading.

- **API7:2023 - Server Side Request Forgery**

  Server-Side Request Forgery (SSRF) flaws can occur when an API is

This website uses cookies to analyze our traffic and only share that information with our analytics partners. Accept

to an unexpected destination, even when protected by a firewall or a VPN. Continue reading.

- **API8:2023 - Security Misconfiguration**

  APIs and the systems supporting them typically contain complex configurations, meant to make the APIs more customizable. Software and DevOps engineers can miss these configurations, or don't follow security best practices when it comes to configuration, opening the door for different types of attacks. Continue reading.

- **API9:2023 - Improper Inventory Management**

  APIs tend to expose more endpoints than traditional web applications, making proper and updated documentation highly important. A proper inventory of hosts and deployed API versions also are important to mitigate issues such as deprecated API versions and exposed debug endpoints. Continue reading.

- **API10:2023 - Unsafe Consumption of APIs**

  Developers tend to trust data received from third-party APIs more than user input, and so tend to adopt weaker security standards. In order to

This website uses cookies to analyze our traffic and only share that information with our analytics partners. Accept

Licensing

The OWASP API Security Project documents are free to use!

The OWASP API Security Project is licensed under the Creative Commons Attribution-ShareAlike 4.0 license, so you can copy, distribute and transmit the work, and you can adapt it, and use it commercially, but all provided that you attribute the work and if you alter, transform, or build upon this work, you may distribute the resulting work only under the same or similar license to this one.

Edit on GitHub

Spotlight: Digital.ai

digital.ai™

Digital.ai is an industry-leading technology company dedicated to helping Global 5000 enterprises automate software delivery workflows across complex technology environments. The company's AI-powered DevSecOps platform automates software releases, improves mobile application testing and security, and provides insights across the software lifecycle. Digital.ai empowers large enterprises to embrace AI responsibly, reduce software-related risk, and amplify developer productivity to deliver innovations that drive business outcomes.

Corporate Supporters

This website uses cookies to analyze our traffic and only share that information with our analytics partners. Accept













Become a corporate supporter

HOME PROJECTS CHAPTERS EVENTS ABOUT

PRIVACY SITEMAP CONTACT

OWASP, the OWASP logo, and Global AppSec are registered trademarks and AppSec Days, AppSec California, AppSec Cali, SnowFROC, OWASP Boston Application Security Conference, and LASCON are trademarks of the OWASP Foundation, Inc. Unless otherwise specified, all content on the site is Creative Commons Attribution-ShareAlike v4.0 and provided without warranty of service or accuracy. For more information, please refer to our General Disclaimer. OWASP does not endorse or recommend commercial products or services, allowing our community to remain vendor neutral with the collective wisdom of the best minds in software security worldwide. Copyright 2025, OWASP Foundation, Inc.

This website uses cookies to analyze our traffic and only share that information with our analytics partners.

Accept